

ENCUESTA INTEGRAL DE CIBERSEGURIDAD ORGANIZACIONAL

Esquema Nacional de Seguridad (Real Decreto 311/2022) - Kit de Evaluación 2026

PORTADA EJECUTIVA

Institución Responsable: Consorcio de Científicos de Datos y Estrategas de Ciberseguridad

Período de Aplicación: 2026

Versión: 1.0 Integral

Clasificación: Público

Estimado de Tiempo: 45-90 minutos

Formato: Digital (Google Forms / SurveyMonkey / Qualtrics)

INTRODUCCIÓN Y CONTEXTO

Esta encuesta integral ha sido diseñada para evaluar la **madurez, conformidad y resiliencia** de organizaciones públicas y privadas españolas en materia de ciberseguridad, alineada con:

- Real Decreto 311/2022 (Esquema Nacional de Seguridad - ENS)
- NIST Cybersecurity Framework 2.0
- Directiva NIS2 (Operadores esenciales/importantes)
- ISO 27001:2022

El propósito es **doble**: (1) generar un diagnóstico basal de la postura de seguridad, y (2) construir un **Índice de Gestión de Madurez (IGM)** con **ROI cuantificable**.

SECCIÓN I: INFORMACIÓN ORGANIZACIONAL

I.1 Datos Generales

P1. ¿Cuál es la razón social de su organización?

Campo abierto de texto

P2. Sector institucional/empresarial:

- ☐ Administración Pública (Central/AGE)
- ☐ Administración Autonómica (CCAA)
- ☐ Administración Local (Ayuntamiento, Diputación)
- ☐ Sanidad (Hospital, Centro Salud, Entidad SNS)
- ☐ Educación (Universidad, Centro Educativo)
- ☐ Finanzas/Banca
- ☐ Energía
- ☐ Telecomunicaciones/TIC
- ☐ Agua/Servicios Esenciales
- ☐ Transporte/Logística

- ☐ Manufactura/Industria
- ☐ Servicios Profesionales
- ☐ Otros (especificar): _____

P3. Número de empleados:

- ☐ Micro (< 10)
- ☐ Pequeña (10-49)
- ☐ Mediana (50-249)
- ☐ Grande (250-999)
- ☐ Muy Grande (> 1.000)

P4. ¿Su organización es operador esencial u importante según NIS2 Directive?

- ☐ Sí, operador esencial
- ☐ Sí, operador importante
- ☐ No, pero cumple con ENS
- ☐ No, sin obligación normativa directa
- ☐ No lo sé

P5. Presupuesto anual destinado a ciberseguridad (último año):

- ☐ < 5.000€
- ☐ 5.000€ - 25.000€
- ☐ 25.000€ - 100.000€
- ☐ 100.000€ - 500.000€
- ☐ 500.000€ - 2.000.000€
- ☐ > 2.000.000€
- ☐ No disponible / No cuantificado

SECCIÓN II: MARCO ORGANIZATIVO (Art. 12-15, Anexo II ENS)

II.1 Política de Seguridad

P6. ¿Existe una Política de Seguridad de la Información documentada y actualizada?

- ☐ No existe
- ☐ Existe pero no está documentada formalmente
- ☐ Existe, documentada, pero sin fecha de actualización clara (>2 años)
- ☐ Existe, documentada, actualizada (últimos 2 años)
- ☐ Existe, documentada, actualizada anualmente, con aprobación ejecutiva
- ☐ Existe, documentada, actualizada anualmente, con aprobación ejecutiva + revisiones trimestrales

P7. ¿La Política incluye objetivos de seguridad cuantificables?

- ☐ No
- ☐ Parcialmente (algunos objetivos mencionados sin métricas)
- ☐ Sí, con objetivos generales (reducir incidentes, mejorar formación)

- ☐ Sí, con objetivos SMART (específicos, medibles, alcanzables, relevantes, con plazo)
- ☐ Sí, con objetivos SMART + KPIs alineados a negocio + revisión trimestral

P8. ¿La Política se comunica a todos los empleados?

- ☐ No se comunica
- ☐ Se comunica a directivos únicamente
- ☐ Se comunica a todos, sin verificación de comprensión
- ☐ Se comunica + capacitación obligatoria + quiz de verificación
- ☐ Se comunica + capacitación + quiz + seguimiento anual de cumplimiento

II.2 Estructura Organizativa y Responsabilidades

P9. ¿Existe un rol definido de Responsable de Seguridad (CISO o equivalente)?

- ☐ No existe
- ☐ Existe, pero sin dedicación exclusiva (es parte de otras funciones)
- ☐ Existe, con dedicación parcial (50-75% del tiempo)
- ☐ Existe, con dedicación exclusiva (100%)
- ☐ Existe + equipo de ciberseguridad (3-5 personas) + CISO dedicado

P10. Nivel jerárquico del CISO:

- ☐ Reporta a TI/Infraestructura
- ☐ Reporta a Subdirección/Gerencia
- ☐ Reporta a Dirección General
- ☐ Reporta a Consejo/Junta Directiva
- ☐ No aplica (sin CISO)

P11. ¿Se han definido roles y responsabilidades de seguridad en política formal?

- ☐ No
- ☐ Sí, documentadas en política, pero sin distribución formal
- ☐ Sí, documentadas + matriz RACI distribuida
- ☐ Sí, documentadas + matriz RACI + capacitación roles + seguimiento
- ☐ Sí, documentadas + matriz RACI + capacitación + auditoría anual de conformidad

P12. ¿Existe un Comité de Seguridad (u órgano equivalente) con periodicidad de reuniones?

- ☐ No existe
- ☐ Existe, pero se reúne < 2 veces/año
- ☐ Existe, se reúne 2-4 veces/año
- ☐ Existe, se reúne mensualmente
- ☐ Existe, se reúne mensualmente + actas + seguimiento de acciones

II.3 Gestión de Riesgos

P13. ¿Existe un proceso documentado de análisis de riesgos de seguridad?

- ☐ No existe
- ☐ Existe informalmente (sin metodología clara)
- ☐ Existe, documentado, pero sin estructura formal

- ☐ Existe, documentado, sigue metodología estándar (NIST, ISO 31000)
- ☐ Existe, documentado, metodología estándar + herramientas cuantitativas (FAIR, CAsPeA)

P14. ¿Con qué frecuencia se realiza evaluación de riesgos?

- ☐ No se realiza
- ☐ Ad-hoc (solo tras incidentes)
- ☐ Anualmente
- ☐ Semestralmente
- ☐ Trimestralmente o más frecuente

P15. ¿Se documentan y rastrean riesgos identificados?

- ☐ No se documentan
- ☐ Se documentan informalmente (hojas de cálculo)
- ☐ Se documentan en herramienta de registro centralizado
- ☐ Se documentan + se clasifican por criticidad + se asignan propietarios + se monitorean trimestral
- ☐ Se documentan + clasifican + asignan + monitorean + se vinculan a tratamientos cuantitativos

P16. ¿Existe un plan de tratamiento de riesgos identificados?

- ☐ No existe
- ☐ Existe, pero es informal
- ☐ Existe, documentado, con acciones identificadas
- ☐ Existe, documentado, con acciones + responsables + fechas + presupuestos
- ☐ Existe, documentado + acciones + responsables + fechas + presupuestos + seguimiento bimensual

SECCIÓN III: MARCO OPERACIONAL (Art. 18-31, Anexo II ENS)

III.1 Planificación y Gestión de Cambios

P17. ¿Existe un Plan de Seguridad alineado a la Política?

- ☐ No existe
- ☐ Existe informalmente
- ☐ Existe documentado, pero sin conexión clara a política
- ☐ Existe documentado, alineado + objetivos anuales + presupuesto asignado
- ☐ Existe documentado, alineado + objetivos anuales + presupuesto + revisión trimestral

P18. ¿Se realiza clasificación de activos de información?

- ☐ No se realiza
- ☐ Se realiza informalmente
- ☐ Se realiza para sistemas críticos únicamente
- ☐ Se realiza para todos los activos, usando criterios documentados (públicos, internos, confidencial, restringido)
- ☐ Se realiza + se documenta en registro centralizado + se revisa anualmente

P19. ¿Existe un proceso documentado de gestión de cambios en sistemas/aplicaciones?

- ☐ No existe

- ☐ Existe, pero informal
- ☐ Existe documentado, con evaluación de impacto de seguridad
- ☐ Existe documentado + evaluación seguridad + aprobación requerida + registro centralizado
- ☐ Existe documentado + evaluación + aprobación + registro + auditoría trimestral de conformidad

P20. ¿Se realiza planificación de continuidad de negocio / recuperación ante desastres?

- ☐ No existe
- ☐ Existe un Plan, pero no documentado
- ☐ Existe documentado, pero sin pruebas
- ☐ Existe documentado + RTO/RPO definidos + simulacro anual
- ☐ Existe documentado + RTO/RPO + simulacros semestrales + métricas de efectividad

III.2 Control de Acceso (Identificación, Autenticación, Autorización)

P21. ¿Se implementa autenticación única (SSO / Identity Provider)?

- ☐ No
- ☐ Parcialmente (algunos sistemas)
- ☐ Sí, pero sin MFA
- ☐ Sí, con MFA para usuarios críticos
- ☐ Sí, con MFA obligatorio para todos los usuarios

P22. ¿Cuál es la política de contraseñas implementada?

- ☐ No existe política formal
- ☐ Existe, pero permite contraseñas débiles (< 8 caracteres)
- ☐ Existe, requiere 8+ caracteres, sin requisitos de complejidad
- ☐ Existe, requiere 12+ caracteres + complejidad + historial
- ☐ Existe, requiere 12+ caracteres + complejidad + historial + cambio periódico + integración con SIEM

P23. ¿Se auditan regularmente los accesos de usuarios?

- ☐ No se audita
- ☐ Se audita anualmente
- ☐ Se audita semestralmente
- ☐ Se audita trimestralmente + se documentan inconsistencias
- ☐ Se audita continuamente con herramientas automáticas (PAM, IAM) + alertas

P24. ¿Se implementa principio de menor privilegio (PoLP)?

- ☐ No
- ☐ Parcialmente (para usuarios críticos)
- ☐ Sí, para administradores
- ☐ Sí, para administradores + usuarios finales + acceso por rol documentado
- ☐ Sí, implementado + auditoría trimestral + revisión de abusos

P25. ¿Se realiza revisión de derechos de acceso tras cambios organizacionales?

- ☐ No
- ☐ Ad-hoc (cuando se detectan problemas)

- ☐ Anualmente
- ☐ Semestralmente
- ☐ Trimestralmente o más frecuente

III.3 Explotación de Sistemas y Seguridad de Redes

P26. ¿Se utiliza Firewall perimetral?

- ☐ No
- ☐ Sí, pero no configurado actualmente
- ☐ Sí, configurado, sin monitoreo activo
- ☐ Sí, configurado + monitoreo + alertas
- ☐ Sí, configurable dinámicamente + monitoreo + alertas + auditoría anual de reglas

P27. ¿Se segmenta la red (DMZ, segmentación interna)?

- ☐ No
- ☐ Parcialmente (DMZ únicamente)
- ☐ Sí, segmentación básica
- ☐ Sí, segmentación por criticidad + VLANs
- ☐ Sí, micro-segmentación + zero-trust + monitoreo tráfico este-oeste

P28. ¿Se implementa monitoreo centralizado de eventos de seguridad (SIEM)?

- ☐ No
- ☐ Sí, herramienta básica (alertas simples)
- ☐ Sí, SIEM con correlación de eventos + análisis de logs
- ☐ Sí, SIEM + análisis + alertas customizadas + dashboards
- ☐ Sí, SIEM + análisis + alertas + dashboards + IA/ML para detección de anomalías

P29. ¿Se rastrea quién accede a qué información (trazabilidad)?

- ☐ No
- ☐ Parcialmente (sistemas críticos únicamente)
- ☐ Sí, logs centralizados, pero sin análisis regular
- ☐ Sí, logs centralizados + análisis mensual
- ☐ Sí, logs centralizados + análisis automático + alertas + retención > 1 año

P30. ¿Se implementan controles de comunicaciones seguras (cifrado, VPN)?

- ☐ No
- ☐ Parcialmente (algunos sistemas)
- ☐ Sí, para datos en tránsito sensibles
- ☐ Sí, para todos los datos en tránsito + datos en reposo en servidores
- ☐ Sí, cifrado extremo a extremo + datos en reposo + claves gestionadas centralmente

SECCIÓN IV: MEDIDAS DE PROTECCIÓN (Anexo II ENS)

IV.1 Protección de Infraestructura

P31. ¿Se realiza mantenimiento preventivo de sistemas (parches, actualizaciones)?

- ☐ No
- ☐ Ad-hoc (cuando fallan sistemas)
- ☐ Mensualmente
- ☐ Semanalmente
- ☐ Semanalmente + planificado + documentado + con ventanas de cambio

P32. ¿Se aplican parches críticos de seguridad en qué plazo?

- ☐ Nunca / Desconocido
- ☐ > 60 días
- ☐ 30-60 días
- ☐ 7-30 días
- ☐ < 7 días + seguimiento automático

P33. ¿Se implementan protecciones contra malware?

- ☐ No
- ☐ Antivirus únicamente (definiciones < 7 días)
- ☐ Antivirus + anti-spyware + análisis heurístico
- ☐ Endpoint Protection Platform (EPP) + EDR
- ☐ EPP + EDR + IA/ML + sandbox + inteligencia de amenazas

P34. ¿Se monitorean puntos finales (endpoints)?

- ☐ No
- ☐ Parcialmente (algunos equipos)
- ☐ Sí, inventario de equipos
- ☐ Sí, inventario + estado de seguridad (parches, antivirus)
- ☐ Sí, inventario + estado + comportamiento anómalo + alertas

P35. ¿Se implementan controles de dispositivos removibles (USB, CDs)?

- ☐ No
- ☐ Prohibición, pero no técnicamente enforced
- ☐ Prohibición + control técnico (bloqueado)
- ☐ Prohibición técnica + excepciones documentadas + cifrado requerido
- ☐ Prohibición técnica + excepciones + cifrado + auditoría trimestral

IV.2 Protección de Datos

P36. ¿Se realiza copias de seguridad (backups) regularmente?

- ☐ No
- ☐ Irregularmente (cuando se recuerda)
- ☐ Diariamente, pero sin verificación

- ☐ Diariamente + restauración testada semanalmente
- ☐ Diariamente + restauración testada + 3-2-1 rule + almacenamiento geográficamente disperso

P37. ¿Se prueba la capacidad de recuperación de backups?

- ☐ No
- ☐ Anualmente
- ☐ Semestralmente
- ☐ Trimestralmente
- ☐ Mensualmente

P38. ¿Se implementa encriptación de datos en reposo?

- ☐ No
- ☐ Parcialmente (datos sensibles únicamente)
- ☐ Sí, para bases de datos
- ☐ Sí, para bases de datos + almacenamientos conectados
- ☐ Sí, para todos los almacenamientos + gestión de claves centralizada

P39. ¿Se etiquetan datos según clasificación (público, interno, confidencial)?

- ☐ No
- ☐ Informalmente
- ☐ Sí, para documentos críticos
- ☐ Sí, para todos los documentos (política formal)
- ☐ Sí, etiquetado automático + DLP + seguimiento + auditoría trimestral

P40. ¿Se implementan controles de Data Loss Prevention (DLP)?

- ☐ No
- ☐ Básico (bloqueo de archivos ejecutables)
- ☐ Moderado (control de copias de datos clasificados)
- ☐ Avanzado (monitoreo de canal de comunicación + alertas)
- ☐ Avanzado + orquestación automática de respuestas

IV.3 Seguridad de Aplicaciones

P41. ¿Se realiza revisión de código (code review) antes de deploy?

- ☐ No
- ☐ Informalmente
- ☐ Sí, para aplicaciones críticas
- ☐ Sí, para todas las aplicaciones + checklist de seguridad
- ☐ Sí, para todas + checklist + herramientas de análisis automático (SAST)

P42. ¿Se realiza testing de seguridad de aplicaciones (SAST/DAST)?

- ☐ No
- ☐ Anualmente
- ☐ Semestralmente

- ☐ Trimestralmente o mensualmente
- ☐ Continuamente (CI/CD integrado)

P43. ¿Se realiza prueba de penetración de aplicaciones web?

- ☐ No
- ☐ Nunca realizada
- ☐ Anualmente
- ☐ Semestralmente
- ☐ Trimestralmente + con hallazgos documentados + remediación tracked

P44. ¿Se implementan controles de inyección SQL, XSS, CSRF?

- ☐ No (aplicación vulnerable)
- ☐ Parcialmente (algunos controles)
- ☐ Sí, implementados manualmente
- ☐ Sí, implementados + validados en testing
- ☐ Sí, implementados + validados + monitoreo de exploits + alertas

P45. ¿Se utiliza Web Application Firewall (WAF)?

- ☐ No
- ☐ Sí, pero sin reglas customizadas
- ☐ Sí, con reglas estándar
- ☐ Sí, con reglas customizadas + monitoreo
- ☐ Sí, con reglas + monitoreo + IA/ML para patrones de ataque

SECCIÓN V: GESTIÓN DE INCIDENTES Y RESPUESTA (Art. 33-34, Anexo II ENS)

V.1 Detección y Análisis de Incidentes

P46. ¿Se ha documentado un procedimiento de respuesta a incidentes?

- ☐ No existe
- ☐ Existe, pero no documentado
- ☐ Existe documentado, pero sin pruebas
- ☐ Existe documentado + equipo designado + plan de activación
- ☐ Existe documentado + equipo + plan + simulacro anual + métricas MTTD/MTTR

P47. ¿Cuál es el Tiempo Medio de Detección (MTTD) de incidentes?

- ☐ Desconocido
- ☐ > 30 días (detección reactiva)
- ☐ 7-30 días
- ☐ 24-72 horas
- ☐ < 24 horas (detección proactiva)

P48. ¿Cuál es el Tiempo Medio de Respuesta (MTTR)?

- ☐ Desconocido
- ☐ > 7 días

- ☐ 3-7 días
- ☐ 1-3 días
- ☐ < 1 día (automatizado para incidentes de rutina)

P49. ¿Se rastrea y reporta automáticamente incidentes?

- ☐ No
- ☐ Manualmente (sin herramienta)
- ☐ Con herramienta básica (ticketing manual)
- ☐ Con herramienta + automatización parcial de alertas
- ☐ Con plataforma completa (SOAR) + automatización + orquestación

P50. ¿Se realiza análisis forense de incidentes?

- ☐ No
- ☐ Parcialmente (solo incidentes críticos)
- ☐ Sí, para todos los incidentes
- ☐ Sí, con reporte formal + lecciones aprendidas documentadas
- ☐ Sí, con reporte + lecciones + implementación de mejoras + seguimiento

V.2 Indicadores Clave de Respuesta a Incidentes

P51. ¿Cuántos incidentes de seguridad ocurrieron en el último año?

- ☐ 0 (improbable) / Desconocido
- ☐ 1-5
- ☐ 6-20
- ☐ 21-50
- ☐ > 50

P52. ¿Cuál fue la tasa de incidentes por 1.000 usuarios/año?

- ☐ > 10 (tasa alta)
- ☐ 5-10
- ☐ 1-5
- ☐ 0,1-1
- ☐ < 0,1 (tasa baja)

P53. ¿Cuántos incidentes resultaron en exposición de datos personales?

- ☐ 0
- ☐ 1-2
- ☐ 3-5
- ☐ 6-10
- ☐ > 10

P54. ¿Se reportan incidentes a AEPD (datos personales), CCN-CERT u otras autoridades?

- ☐ No, nunca ha sido necesario
- ☐ No, pero debería
- ☐ Sí, ocasionalmente

- ☐ Sí, sistemáticamente + documentado
- ☐ Sí, sistemáticamente + documentado + análisis de tendencias

P55. ¿Se realiza comunicación post-incidente a afectados?

- ☐ No se realiza
- ☐ Se realiza, pero sin protocolo formal
- ☐ Se realiza siguiendo procedimiento
- ☐ Se realiza siguiendo procedimiento + plantillas estandarizadas
- ☐ Se realiza + procedimiento + plantillas + análisis de impacto reputacional

SECCIÓN VI: ANÁLISIS DE VULNERABILIDADES Y PRUEBAS DE PENETRACIÓN

VI.1 Análisis de Vulnerabilidades

P56. ¿Se realiza escaneo automático de vulnerabilidades?

- ☐ No
- ☐ Sí, pero < 2 veces/año
- ☐ Sí, mensualmente
- ☐ Sí, semanalmente
- ☐ Sí, continuamente (CI/CD integrado) + alertas en tiempo real

P57. ¿Con qué herramientas se realizan los escaneos?

- ☐ Sin herramientas especializadas
- ☐ Herramientas básicas (Nessus, OpenVAS sin configuración avanzada)
- ☐ Herramientas estándar bien configuradas
- ☐ Múltiples herramientas + correlación de resultados
- ☐ Stack completo (SAST/DAST/IaC/SCA) + integración DevSecOps

P58. ¿Cuál es el tiempo de remediación de vulnerabilidades críticas?

- ☐ No se remedia (los sistemas permanecen vulnerables)
- ☐ > 90 días
- ☐ 30-90 días
- ☐ 7-30 días
- ☐ < 7 días + seguimiento automático

P59. ¿Se realiza seguimiento de CVEs (Common Vulnerabilities and Exposures)?

- ☐ No
- ☐ Manualmente (lectura de NVD)
- ☐ Herramienta de monitoreo de CVEs
- ☐ Herramienta + alertas automáticas + evaluación de impacto
- ☐ Herramienta + alertas + evaluación + mapeo de sistemas afectados + priorización automática

P60. ¿Se implementan controles mitigadores antes de parches?

- ☐ No
- ☐ Ocasionalmente

- ☐ Sí, para vulnerabilidades críticas
- ☐ Sí, para críticas + altas + documentados en plan de riesgos
- ☐ Sí, para todas las clasificaciones + seguimiento de efectividad

VI.2 Pruebas de Penetración

P61. ¿Se realiza prueba de penetración externa?

- ☐ Nunca
- ☐ Cada 2-3 años
- ☐ Anualmente
- ☐ Semestralmente
- ☐ Trimestralmente o más frecuente

P62. ¿Se realiza prueba de penetración interna?

- ☐ Nunca
- ☐ Cada 2-3 años
- ☐ Anualmente
- ☐ Semestralmente
- ☐ Trimestralmente o más frecuente

P63. ¿Se realiza prueba de penetración de aplicaciones web?

- ☐ Nunca
- ☐ Cada 2-3 años
- ☐ Anualmente
- ☐ Cada cambio mayor (ad-hoc)
- ☐ Continuamente (preproducción) + anual en producción

P64. ¿Se realiza prueba de penetración de seguridad física?

- ☐ No aplica
- ☐ Nunca
- ☐ Cada 2-3 años
- ☐ Anualmente
- ☐ Anualmente + pruebas de ingeniería social

P65. ¿Se realiza prueba de penetración de seguridad social (phishing simulado)?

- ☐ No
- ☐ Anualmente
- ☐ Semestralmente
- ☐ Trimestralmente
- ☐ Mensualmente + métricas de tasa de clics/reportes

P66. ¿Se documentan hallazgos de pruebas de penetración?

- ☐ No se realizan pruebas
- ☐ Se realizan pero sin documentación
- ☐ Se documentan informalmente

- ☐ Se documentan + plan de remediación + seguimiento
- ☐ Se documentan + plan + seguimiento + análisis de tendencias año a año

P67. ¿Se asignan propietarios para remediar hallazgos de penetración?

- ☐ No
- ☐ Sí, pero sin seguimiento
- ☐ Sí, con seguimiento informal
- ☐ Sí, con seguimiento formal + reportes mensuales
- ☐ Sí, con seguimiento + SLAs + escalación automática

P68. ¿Cuál es el porcentaje de hallazgos de penetración remediados?

- ☐ < 20%
- ☐ 20-50%
- ☐ 50-80%
- ☐ 80-95%
- ☐ > 95% (solo acepciones documentadas)

SECCIÓN VII: SEGURIDAD OPERACIONAL (SIEM, Monitoreo, Alertas)

VII.1 Implementación de SIEM

P69. ¿Se implementa una solución SIEM (Security Information and Event Management)?

- ☐ No
- ☐ Sí, pero en fase piloto
- ☐ Sí, parcialmente (algunos sistemas conectados)
- ☐ Sí, completamente + todos los sistemas conectados
- ☐ Sí, completo + análisis avanzado + IA/ML + inteligencia de amenazas

P70. ¿Qué sistemas se conectan al SIEM?

- ☐ Sin SIEM
- ☐ Firewalls únicamente
- ☐ Firewalls + servidores críticos
- ☐ Todos los servidores + aplicaciones + endpoints
- ☐ Todos los anteriores + nube + dispositivos IoT + sincronizado con SOC

P71. ¿Se monitorean eventos de acceso (logins, cambios de permisos)?

- ☐ No
- ☐ Parcialmente
- ☐ Sí, para administradores
- ☐ Sí, para administradores + usuarios críticos + con alertas
- ☐ Sí, para todos + con alertas + análisis de patrones anómalos

P72. ¿Se analizan logs de firewall/IDS para patrones de ataque?

- ☐ No
- ☐ Manualmente (lectura ad-hoc)

- ☐ Análisis automático básico
- ☐ Análisis automático + alertas + correlación
- ☐ Análisis automático + alertas + correlación + IA/ML + CTI integration

P73. ¿Se detectan intentos de acceso no autorizados?

- ☐ No
- ☐ Ocasionalmente
- ☐ Sí, pero con muchos falsos positivos
- ☐ Sí, con pocos falsos positivos + tasa de detección > 80%
- ☐ Sí, tasa detección > 95% + muy pocos falsos positivos

VII.2 Métricas de Seguridad Operacional

P74. ¿Se rastrea el volumen de alertas SIEM?

- ☐ No se rastrea
- ☐ Se rastrea manualmente
- ☐ Se rastrea automáticamente en dashboard
- ☐ Se rastrea + se ajustan reglas si hay > X alertas/día
- ☐ Se rastrea + dashboard + ajuste automático de reglas + análisis de tendencias

P75. ¿Cuál es la tasa de falsos positivos del SIEM?

- ☐ No se mide
- ☐ > 80% (sistema no confiable)
- ☐ 50-80%
- ☐ 20-50%
- ☐ < 20% (buen balance)

P76. ¿Se mide el MTTD en el contexto del SIEM?

- ☐ No se mide
- ☐ Se mide trimestralmente
- ☐ Se mide mensualmente
- ☐ Se mide semanalmente + reportes
- ☐ Se mide continuamente + dashboard en tiempo real

P77. ¿Se implementan alertas automáticas para eventos críticos?

- ☐ No
- ☐ Sí, pero pocas (< 10 reglas)
- ☐ Sí, moderadas (10-50 reglas)
- ☐ Sí, completas (50+ reglas) + categorización por severidad
- ☐ Sí, completas + categorización + playbooks de respuesta automática

P78. ¿Se monitorean intentos de exfiltración de datos?

- ☐ No
- ☐ Parcialmente (DLP únicamente)
- ☐ Sí, con DLP + monitoreo de canales (email, nube, USB)

- ☐ Sí, monitoreo completo + alertas + bloqueo automático
- ☐ Sí, monitoreo + alertas + bloqueo + inteligencia de amenazas

SECCIÓN VIII: CAPACITACIÓN Y CONCIENCIACIÓN (Art. 27, Anexo II ENS)

VIII.1 Programa de Capacitación

P79. ¿Existe un programa formal de capacitación en seguridad?

- ☐ No existe
- ☐ Existe, pero ad-hoc
- ☐ Existe documentado, pero sin estructura clara
- ☐ Existe documentado + calendario + contenido + evaluaciones
- ☐ Existe documentado + calendario + contenido + evaluaciones + presupuesto dedicado

P80. ¿A cuántas personas se imparte capacitación anual?

- ☐ No se imparte
- ☐ < 20% de empleados
- ☐ 20-50% de empleados
- ☐ 50-80% de empleados
- ☐ > 80% de empleados (casi cobertura total)

P81. ¿Cuál es la duración mínima de capacitación en seguridad por empleado/año?

- ☐ No existe mínimo
- ☐ < 1 hora
- ☐ 1-4 horas
- ☐ 4-8 horas
- ☐ > 8 horas

P82. ¿Se realiza capacitación diferenciada por rol?

- ☐ No
- ☐ Sí, solo para administradores
- ☐ Sí, para administradores + usuarios críticos
- ☐ Sí, para varios roles con contenido específico
- ☐ Sí, para todos los roles + contenido personalizado + evaluación

P83. ¿Se imparte capacitación sobre cumplimiento normativo (ENS, NIS2, GDPR)?

- ☐ No
- ☐ Ocasionalmente (cuando nuevo requisito)
- ☐ Anualmente
- ☐ Semestralmente + con actualizaciones
- ☐ Continuamente + integrada en onboarding + actualizaciones trimestrales

VIII.2 Evaluación de Efectividad

P84. ¿Se evalúa la comprensión de empleados tras capacitación?

- ☐ No

- ☐ Se deja participación voluntaria (sin verificación)
- ☐ Se realizan quiz/exámenes simples
- ☐ Se realizan quiz + evaluaciones prácticas
- ☐ Se realizan evaluaciones + se rastrea retención + se remedian brechas

P85. ¿Cuál es la tasa de aprobación de evaluaciones de seguridad?

- ☐ No se evalúa
- ☐ < 50% (baja comprensión)
- ☐ 50-75%
- ☐ 75-90%
- ☐ > 90% (buena comprensión)

P86. ¿Se mide cambio de comportamiento post-capacitación?

- ☐ No
- ☐ Anecdóticamente
- ☐ Mediante indicadores indirectos (incidentes reportados)
- ☐ Mediante simulaciones de phishing + cambios observados
- ☐ Mediante simulaciones + cambios medidos + resultados integrados en KPIs

P87. ¿Se rastrea participación en capacitaciones de forma centralizada?

- ☐ No
- ☐ Manualmente (spreadsheets)
- ☐ Herramienta LMS básica
- ☐ Herramienta LMS + reportes automáticos
- ☐ Herramienta LMS + reportes + análisis de tendencias + recomendaciones

P88. ¿Se adapta contenido de capacitación basado en incidentes ocurridos?

- ☐ No
- ☐ Ocasionalmente
- ☐ Anualmente
- ☐ Semestralmente + contenido revisado
- ☐ Continuamente + ajustes ágiles tras incidentes

VIII.3 Campañas de Concienciación

P89. ¿Se realiza campañas de concienciación en seguridad?

- ☐ No
- ☐ Ocasionalmente
- ☐ Anualmente (una campaña)
- ☐ Semestralmente (2+ campañas)
- ☐ Mensualmente o más frecuente (continuo)

P90. ¿Cuál es el alcance de las campañas?

- ☐ Sin campañas
- ☐ Solo directivos

- ☐ Área de TI únicamente
- ☐ Todos los empleados (cobertura general)
- ☐ Todos + focalizadas por grupo de riesgo

P91. ¿Se utilizan múltiples canales para concienciación?

- ☐ No (sin campañas)
- ☐ Un canal (email o póster)
- ☐ Dos canales (email + póster)
- ☐ Tres o más canales (email + póster + charlas + intranet)
- ☐ Múltiples canales + gamificación + competiciones internas

P92. ¿Se simulan ataques de phishing para evaluar respuesta?

- ☐ No
- ☐ Anualmente
- ☐ Semestralmente
- ☐ Trimestralmente
- ☐ Mensualmente + métricas de clic/reporte

P93. ¿Cuál es la tasa de reportes de phishing simulado?

- ☐ No se mide / No hay simulaciones
- ☐ < 10% (empleados no reportan)
- ☐ 10-30%
- ☐ 30-60%
- ☐ > 60% (buena cultura de reporte)

P94. ¿Se comunican lecciones aprendidas de incidentes?

- ☐ No
- ☐ Ocasionalmente
- ☐ Formal, pero no sistemático
- ☐ Sistemático + documentado + comunicado a la organización
- ☐ Sistemático + comunicado + integrado en capacitación futura

SECCIÓN IX: GOBERNANZA Y CUMPLIMIENTO NORMATIVO

IX.1 Marcos Normativos

P95. ¿Cuál es el nivel de conformidad actual con ENS?

- ☐ No evaluado
- ☐ Bajo (< 40% de requisitos implementados)
- ☐ Medio (40-70%)
- ☐ Alto (70-90%)
- ☐ Muy Alto (> 90%, próximo a cumplimiento total)

P96. ¿Se ha realizado una auditoría formal de ENS?

- ☐ Nunca

- ☐ Una vez (> 3 años)
- ☐ Periódicamente (cada 2-3 años)
- ☐ Anualmente
- ☐ Anualmente + auditoría interna semestral

P97. ¿Se implementan requisitos de NIS2?

- ☐ No aplica / Desconocido
- ☐ En preparación (plan desarrollado)
- ☐ Parcialmente implementado
- ☐ Mayormente implementado (> 70%)
- ☐ Completamente implementado + verificado

P98. ¿Se cumple con GDPR/AEPD en materia de ciberseguridad?

- ☐ No evaluado
- ☐ Parcialmente (algunos controles)
- ☐ Mayormente (70%+)
- ☐ Completamente + DPO asignado + evaluaciones regulares
- ☐ Completamente + DPO + evaluaciones + auditoría externa anual

P99. ¿Se implementan controles ISO 27001:2022?

- ☐ No, pero considerado
- ☐ Sí, parcialmente (algunos controles)
- ☐ Sí, mayormente (70%+)
- ☐ Sí, completamente + documentado
- ☐ Sí, completamente + certificado

IX.2 Auditoría y Mejora Continua

P100. ¿Se realiza auditoría interna de ciberseguridad?

- ☐ Nunca
- ☐ Cada 2-3 años
- ☐ Anualmente
- ☐ Semestralmente
- ☐ Trimestralmente o más frecuente

P101. ¿Se realiza auditoría externa de ciberseguridad?

- ☐ Nunca
- ☐ Cada 2-3 años
- ☐ Anualmente
- ☐ Semestralmente
- ☐ Anualmente (mínimo)

P102. ¿Se documentan no conformidades encontradas en auditorías?

- ☐ No se realizan auditorías
- ☐ Se realizan pero no se documentan formalmente

- ☐ Se documentan informalmente
- ☐ Se documentan + se asignan responsables + fechas de remediación
- ☐ Se documentan + asignan + rastrean + se verifica cierre + se reporta a ejecutiva

P103. ¿Se implementan mejoras identificadas en auditorías?

- ☐ No
- ☐ Parcialmente (algunas)
- ☐ Mayormente (70%+)
- ☐ Sí, todas con plan documentado
- ☐ Sí, todas + implementadas en plazo + verificadas

P104. ¿Existe un proceso documentado de mejora continua?

- ☐ No existe
- ☐ Existe informalmente
- ☐ Existe documentado, pero sin periodicidad clara
- ☐ Existe documentado + revisión trimestral
- ☐ Existe documentado + revisión trimestral + métricas de efectividad

SECCIÓN X: IMPACTO FINANCIERO Y ROI

X.1 Inversión en Ciberseguridad

P105. ¿Cuál fue el gasto total en ciberseguridad el año pasado?

- ☐ No cuantificado
- ☐ < 10.000€
- ☐ 10.000€ - 50.000€
- ☐ 50.000€ - 200.000€
- ☐ > 200.000€

P106. ¿En qué áreas se invirtió?

- ☐ Hardware/Infraestructura
- ☐ Software/Herramientas
- ☐ Personal (salarios de ciberseguridad)
- ☐ Servicios externos (consultoría, auditoría, penetración testing)
- ☐ Todas las anteriores

P107. ¿Se cuantifica el costo promedio de un incidente?

- ☐ No
- ☐ Estimado informalmente
- ☐ Sí, documentado (últimos 3 años)
- ☐ Sí, documentado + incluye costo directo + reputacional
- ☐ Sí, completo + FAIR modeling + probabilidad de ocurrencia

P108. ¿Se estima el ROI de inversiones en ciberseguridad?

- ☐ No

- ☐ Informalmente
- ☐ Mediante comparación con industria
- ☐ Mediante análisis interno (costo-beneficio)
- ☐ Mediante análisis + modelo cuantitativo (FAIR) + seguimiento anual

P109. ¿Se documentan ahorros por prevención de incidentes?

- ☐ No
- ☐ Ocasionalmente
- ☐ Anualmente
- ☐ Trimestralmente + incluidos en reportes de seguridad
- ☐ Continuamente + integrados en KPIs de negocio

SECCIÓN XI: INFORMACIÓN ADICIONAL Y CONTEXTO

P110. ¿Cuáles son los tres mayores desafíos de ciberseguridad actuales? (texto libre)

P111. ¿Cuáles son las tres prioridades de ciberseguridad para los próximos 12 meses? (texto libre)

P112. ¿Hay algún incidente reciente significativo que haya impactado la organización? (describir brevemente)

P113. ¿Tiene la organización planes para adoptar tecnologías emergentes (IA, computación cuántica, cloud nativo)?

- ☐ No
- ☐ Considerándose
- ☐ En piloto
- ☐ Parcialmente implementado
- ☐ Completamente implementado

P114. ¿Se ha realizado evaluación de ciberseguridad pre-adopción?

- ☐ N/A
- ☐ No
- ☐ Parcialmente
- ☐ Sí, completamente

OBSERVACIONES FINALES

Agradecemos sinceramente tu participación en esta encuesta integral. Los datos recopilados serán utilizados **exclusivamente para fines de investigación y mejora de la postura de ciberseguridad española**.

El tiempo estimado de respuesta es **45-90 minutos**. Se recomienda involucrar a múltiples departamentos (TI, Seguridad, Cumplimiento, Ejecutiva) para mayor precisión.

Fecha de finalización recomendada: 30 días desde recepción

Versión: 1.0

Última actualización: 24 enero 2026

Clasificación: Público